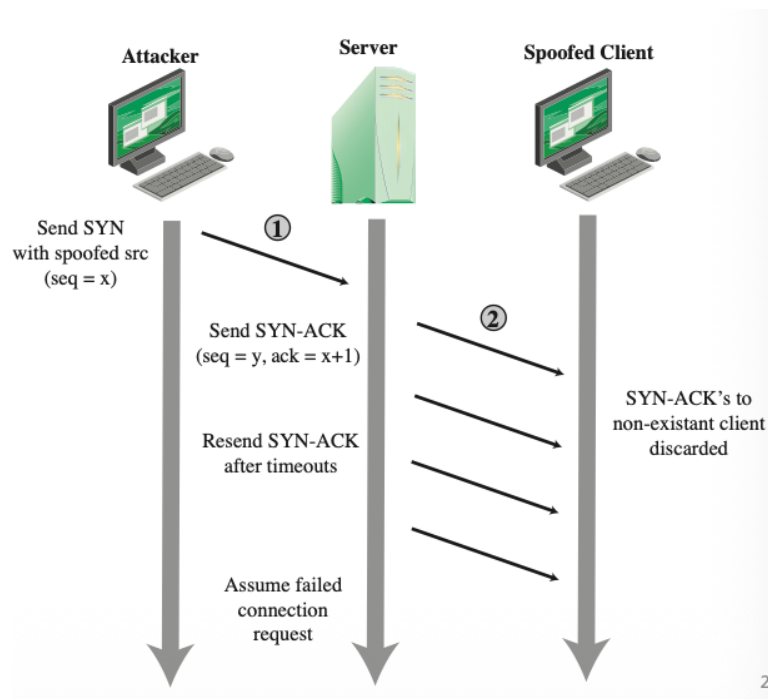


Defenses: Intrusion Detection

Review of Last Time

- Malware
- DoS attacks
- Propagation
 - Infected Content: Viruses
 - Vulnerability Exploit: Worms
 - Social Engineering: Spam E-Mail, Trojans
- Payload
 - System Corruption
 - Attack Agent: Zombie, Bots
 - Information Theft: Keyloggers, Phishing, Spyware
 - Stealthing: Backdoors, Rootkits



Outline

- Overview of intrusion and intrusion detection
- IDS analysis approaches
- IDS data sources

Learning objectives

- Understand anomaly and signature/heuristic approaches for intrusion detection.
理解异常与特征/启发式入侵检测的方法。
- Understand false positive and false negative of an IDS.
- Learn about IDS classification based on the source of data.

Overview

The intruder usually can be divided into four types:

- Cyber criminals
 - Individuals or members of an organized crime group
 - Goal: financial reward
 - Activities: identity theft, theft of financial credentials, data theft, or data ransomware
- Activists
 - Individuals (normally insiders), or members of a larger group of outsider attackers
 - Motivated by social or political causes
 - Activities: website defacement, DoS attacks, or the theft and distribution of data that results in negative publicity
- State-sponsored organizations
 - Groups of hackers sponsored by governments
- Others
 - Hackers with motivations other than those listed above

入侵者主要分为以下四类，他们的动机和行为各不相同：

- **网络罪犯 (Cyber criminals)**：通常是个人或组织犯罪集团成员。其目标是**经济回报**，活动包括身份盗窃、窃取金融凭证或数据勒索。
- **激进分子 (Activists)**：受社会或政治原因驱动。活动通常包括网站篡改（defacement）、拒绝服务攻击（DoS），或通过窃取和分发数据制造负面舆论。
- **国家支持的组织 (State-sponsored organizations)**：由政府赞助的黑客团体，通常针对特定国家或组织进行高精度的攻击。
- **其他 (Others)**：包括那些动机不属于上述类别的黑客，例如内部人员（insiders）或是出于其他个人目的的外部攻击者

Intrusion Detection

Definitions from RFC 2828 (Internet Security Glossary)

- Security Intrusion: A security event, or a combination of multiple security events, that constitutes a security incident in which **an intruder gains, or attempts to gain, access to a system (or system resource) without having authorization to do so.**
安全入侵 (Security Intrusion)：指一个或一组安全事件，其中入侵者**获得或试图获得**对系统（或资源）的未经授权访问。
- Intrusion Detection: A security service that **monitors** and **analyzes** system events for the purpose of finding, and providing real-time or near real-time warning of, attempts to access system resources in an unauthorized manner.
入侵检测 (Intrusion Detection)：这是一种安全服务，通过**监控和分析系统事件**，旨在寻找并提供实时（或近实时）的警告，提醒系统资源正遭受未经授权的访问尝试。

Intrusion Detection System (IDS)

An IDS comprises three logical components:

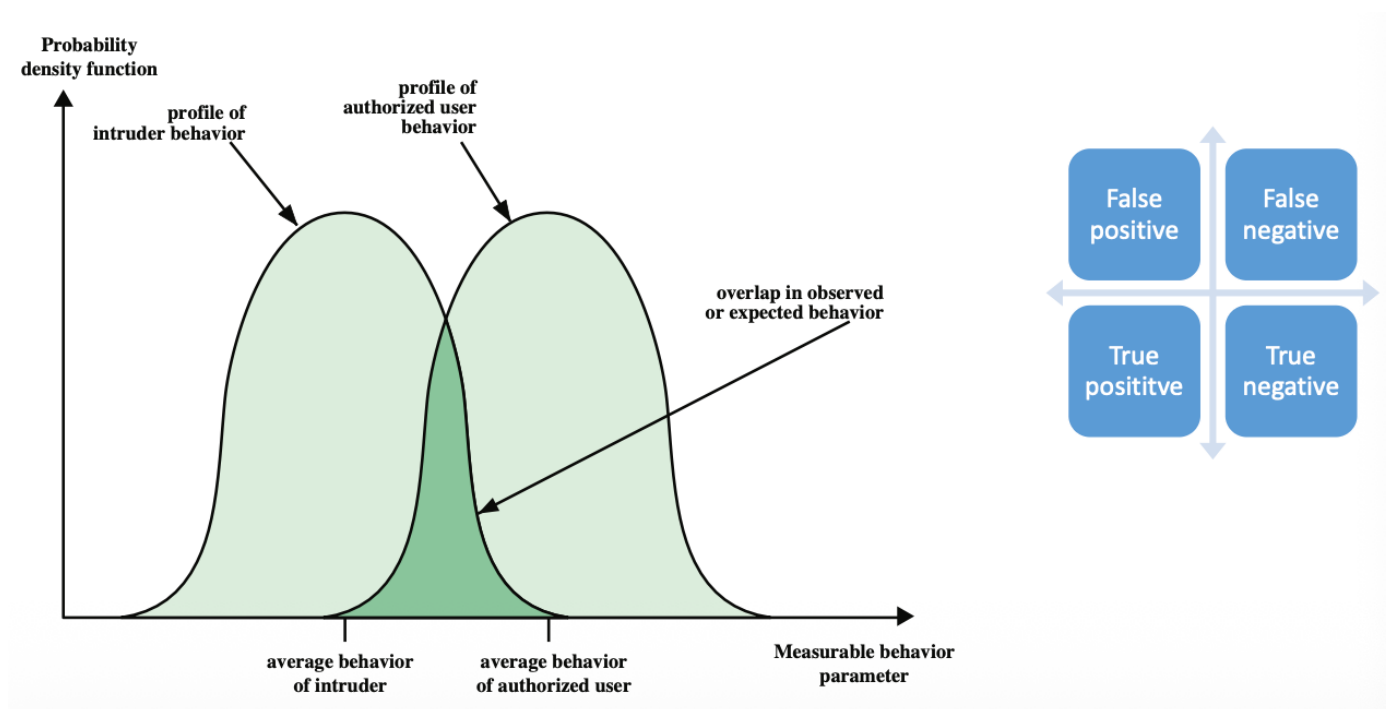
- Sensors
 - collect data (network packets, log files, and system call traces)
- Analyzers
 - determine if intrusion has occurred

- User interface
 - view output or control system behavior

一个完整的入侵检测系统（IDS）由三个逻辑组件构成：

- **传感器 (Sensors)**：负责收集数据，来源包括网络数据包、日志文件和系统调用跟踪。
- **分析器 (Analyzers)**：负责处理传感器收集的数据，并判定入侵是否发生。
- **用户界面 (User interface)**：用于让管理员查看输出结果或控制系统行为。

Profiles of Behavior of Intruders and Authorized Users 行为概貌与判定模型



IDS 通过观察“可测量行为参数”来区分合法用户和入侵者。课件展示了一个概率密度分布图，说明了 IDS 在判定过程中面临的挑战：

- **理想状态**：授权用户和入侵者的行为模式完全分离。
- **现实状态**：两者在观察到的行为中通常存在**重叠（Overlap）**。这导致了四种判定结果：
 - **真阳性 (True Positive)**：正确检测到入侵。
 - **真阴性 (True Negative)**：正确判定为合法行为。
 - **假阳性 (False Positive)**：错误地将合法用户识别为入侵者（也叫虚报）。
 - **假阴性 (False Negative)**：未能检测到实际发生的入侵（也叫漏报）。

IDS Requirements

- Run continually
- Be fault tolerant
- Resist subversion
- Impose a minimal overhead on a system
- Configured according to system security policies
- Adapt to changes in systems and users
- Scale to monitor large number of systems

- Provide graceful degradation of services
- Allow dynamic reconfiguration

为了保证防护效果，一个优秀的 IDS 需要满足以下要求：

- **持续性与容错**：能够持续运行且具备容错能力（Fault tolerant）。
- **抗破坏性**：能够抵御自身的被颠覆或被攻击。
- **低开销**：对受保护系统的性能影响最小化。
- **自适应与扩展**：能够适应系统和用户的变化，并能扩展到监控大量系统。
- **灵活性**：允许动态重新配置，并根据安全策略进行调整。

IDS Analysis Approaches

Analysis Approaches

- Anomaly detection (**Model normal behavior**)
 - Involves the collection of data relating to the behavior of legitimate users over a period of time
 - Current observed behavior is analyzed to determine whether this behavior is that of a legitimate user or that of an intruder
- Signature/Heuristic detection (**Model malicious pattern or behavior**)
 - Uses a set of known malicious data patterns (signature) or attack rules (heuristics)
 - Compares current behavior with the signatures or rules to decide if is that of an intruder
 - Also known as misuse detection
 - Can only identify known attacks for which it has patterns or rules

Anomaly Detection

- Two steps
 - from "Developing a model of legitimate user behavior"
 - to "Current observed behavior is compared with the model in order to classify it as either legitimate or anomalous activity"
- A variety of classification approaches are used:
 - Statistical
 - Analyze the observed behavior using univariate, multivariate, or time-series models of observed metrics
 - Knowledge based
 - Approaches use an expert system that classifies observed behavior according to a set of rules that model legitimate behavior
 - Machine-learning
 - Approaches automatically determine a suitable classification model from the training data using data mining techniques

Anomaly Detection: False Positive

- A **loose** interpretation of intruder behavior, which will catch more intruders, will also lead to a number of **false positives**, where legitimate users are identified as intruders.

Challenge of Anomaly Detection: Baseline Drift

- Normal user and system behavior changes over time
 - Employee promotion → new resource access
 - Project change → new servers/ports
 - Work hour shift → different login times
- Consequence: static baseline increase false positives
- Solutions for adaptive baseline:
 - Sliding Window: train only on last certain numbers of days
 - Weighted Aging: older data is given less weight over time
 - Periodic Retraining: retrain weekly/monthly

Signature or Heuristic Detection

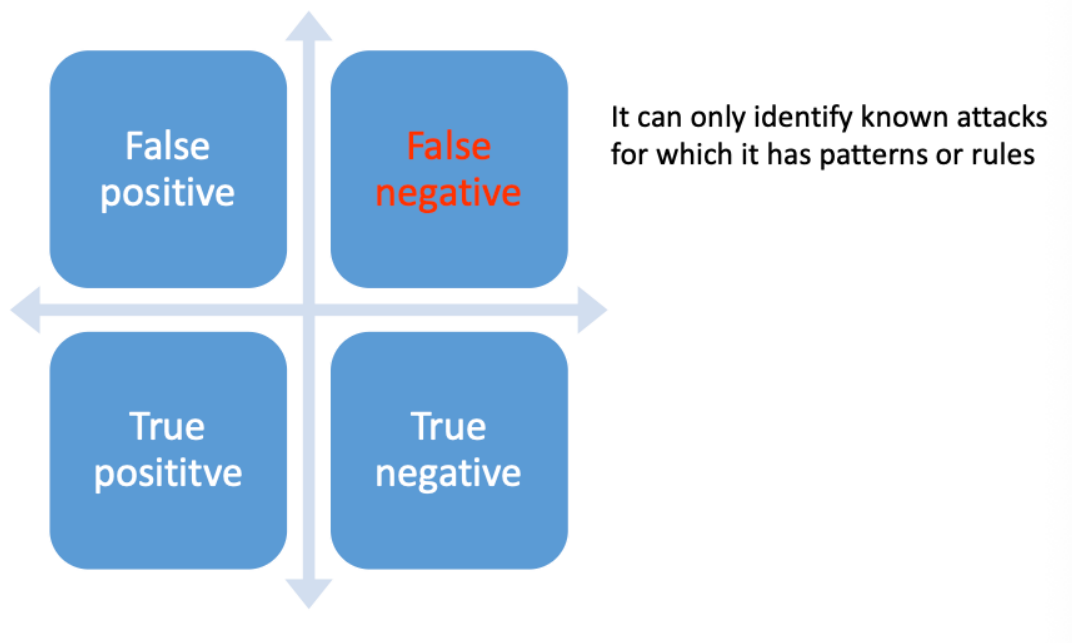
Detects intrusion by observing events in the system and applying a set of signature patterns to the data, or a set of rules that characterize the data, leading to a decision regarding whether the observed data indicates normal or anomalous behavior.

- Signature approaches
 - Match a large collection of known patterns of malicious data against data stored on a system or in transit over a network
 - Widely used in anti-virus products, network traffic scanning proxies, and in NIDS
- Rule-based heuristic identification
 - Involves the use of rules for identifying known penetrations or penetrations that would exploit known weaknesses

Signature vs. Rule-based Heuristic

	Signature Approaches	Rule-based Heuristic
Match against	Content (bytes, strings, patterns)	Behavior (events, sequences, rates)
Detection logic	Does the data contain this exact pattern?	Does the event sequence match an attack rule?
Example	"<'OR'1='1" in HTTP request	10 failed logins from same IP in 60 seconds
Can detect unknown variants?	No (needs new signature)	Sometimes (if behavior matches)
False positive rate	Very low	Low to medium

Signature or Heuristic Detection: False Negative



Exercie

Table 1 shows a testing result of an intrusion detection system. The test includes 10 events (a-j). The "Test" row shows the testing result for each event, where "1" denotes a malicious activity detected and "0" indicates no malicious activity detected. The "Truth" row shows the ground truth if the corresponding event includes a malicious activity or not, "0" means no while "1" means yes. Please count the number of false negative, false positive, true negative, and true positive respectively in terms of Table 1.

Table 1

Event	a	b	c	d	e	f	g	h	i	j
Test	0	0	0	1	1	0	0	1	0	1
Truth	0	1	0	1	0	0	1	1	0	0

IDS Data Source

Data Source

Based on the source and type of data analyzed, IDSs are classified as:

- Host-based IDS (HIDS)
 - Monitors the characteristics of a single host for suspicious activity
- Network-based IDS (NIDS)
 - Monitors network traffic and analyzes network, transport, and application protocols to identify suspicious activity
- Distributed or hybrid IDS
 - Combines information from a number of sensors, often both host and network based, in a central analyzer that is able to better identify and respond to intrusion activity

Host-Based Intrusion Detection (HIDS)

- Adds a specialized layer of security software to vulnerable or sensitive systems

- e.g., database servers and administrative systems
- Can use either anomaly or signature/heuristic approaches
- Monitors activity to detect suspicious behavior
 - Primary purpose is to detect intrusions, log suspicious events, and send alerts
 - Can detect both external and internal intrusions

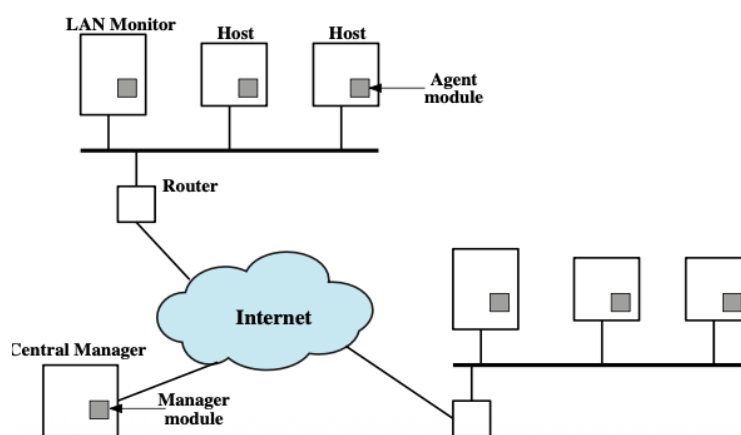
HIDS: Data Sources and Sensors

A fundamental component of intrusion detection is the sensor that collects data

- Common data sources include:
 - System call traces
 - Audit (log file) records
 - File integrity checksums
 - Registry access

HIDS

- Anomaly HIDS
- Signature or Heuristic HIDS
- Distributed HIDS
- Typical organizations which need to defend a distributed collection of hosts supported by a LAN or internetwork.



Architecture for Distributed Intrusion Detection

- Host agent module:
 - Collect data on security-related events on the host
 - Transmit these to the central manager.
- LAN monitor agent module:
 - A host agent module
 - Analyzes LAN traffic and reports the results to the central manager
- Central manager module:
 - Receives reports from LAN monitor and host agents
 - Processes and correlates these reports to detect intrusion.

Network-Based IDS (NIDS)

- Monitors traffic at **a selected points** on the network
- Examines traffic **packet by packet** in real (or close to real) time
- May examine network, transport, and/or application-level protocol activity
- Includes a number of sensors, one or more servers for NIDS management, and one or more management consoles for the human interface
- Analysis of traffic can be done at sensor, the management server, or the combination of the two.
- Can not function well as the increasing use of encryption.

Types of Network Sensors

Sensors can be deployed in one of two modes: inline and passive.

- Inline sensor
 - is inserted into a network segment so that the traffic that it is monitoring must pass through the sensor.
- Passive sensor
 - monitors a copy of network traffic; the actual traffic does not pass through the device.

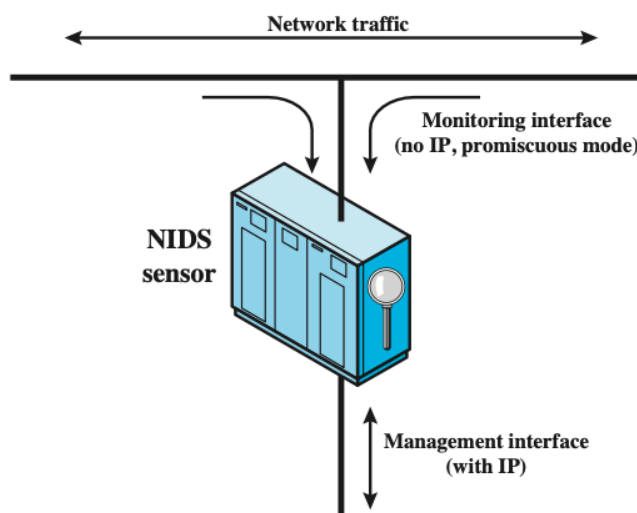
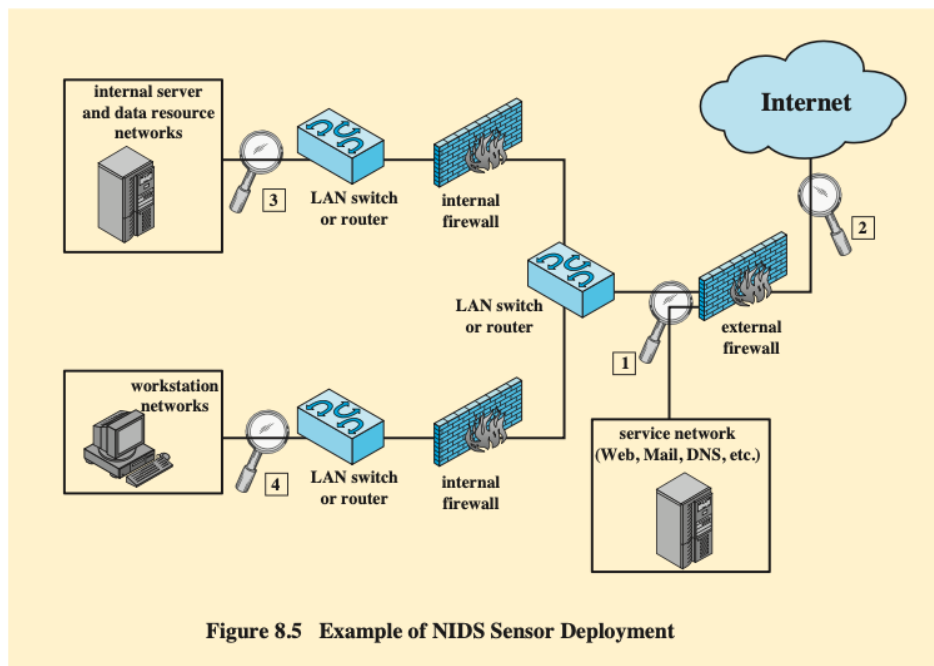


Figure 8.4 Passive NIDS Sensor

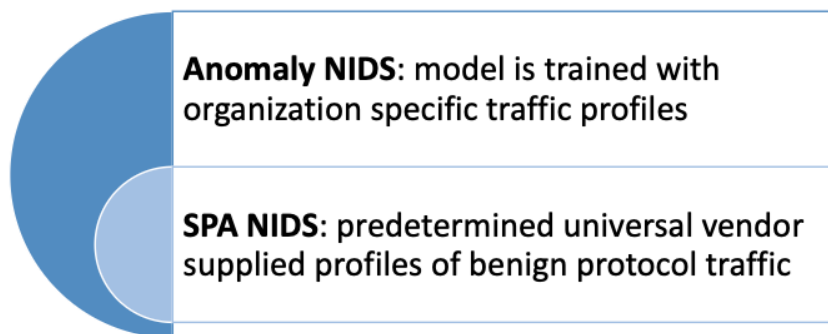
NIDS Sensor Deployment

- Example of NIDS Sensor Deployment



Intrusion Detection Techniques for NIDS

- Signature Detection
- Anomaly Detection Techniques
- Stateful Protocol analysis (SPA)



Honeypots

- Decoy systems designed to:
 - Divert an attacker from accessing critical systems
 - Collect information about the attacker's activity
 - Encourage the attacker to stay on the system long enough for administrators to respond
- These systems are filled with fabricated information that a legitimate user of the system wouldn't access
 - Resources that have no production value
 - Therefore, incoming communication is most likely a probe, scan, or attack
 - Initiated outbound communication suggests that the system has probably been compromised

Honeypot Classifications

Low interaction honeypot

- Consists of a software package that emulates particular IT services or systems well enough to provide a realistic initial interaction, but does not execute a full version of those services or systems
- Provides a less realistic target
- Often sufficient for use as a component of a distributed IDS to warn of imminent attack

High interaction honeypot

- A real system, with a full operating system, services and applications, which are instrumented and deployed where they can be accessed by attackers
- Is a more realistic target that may occupy an attacker for an extended period
- However, it requires significantly more resources
- If compromised could be used to initiate attacks on other systems.

Example of Honeypot Deployment

- The location depends on a number of factors, such as
 - the type of information the organization is interested in gathering
 - the level of risk that organizations can tolerate to obtain the maximum amount of data.

